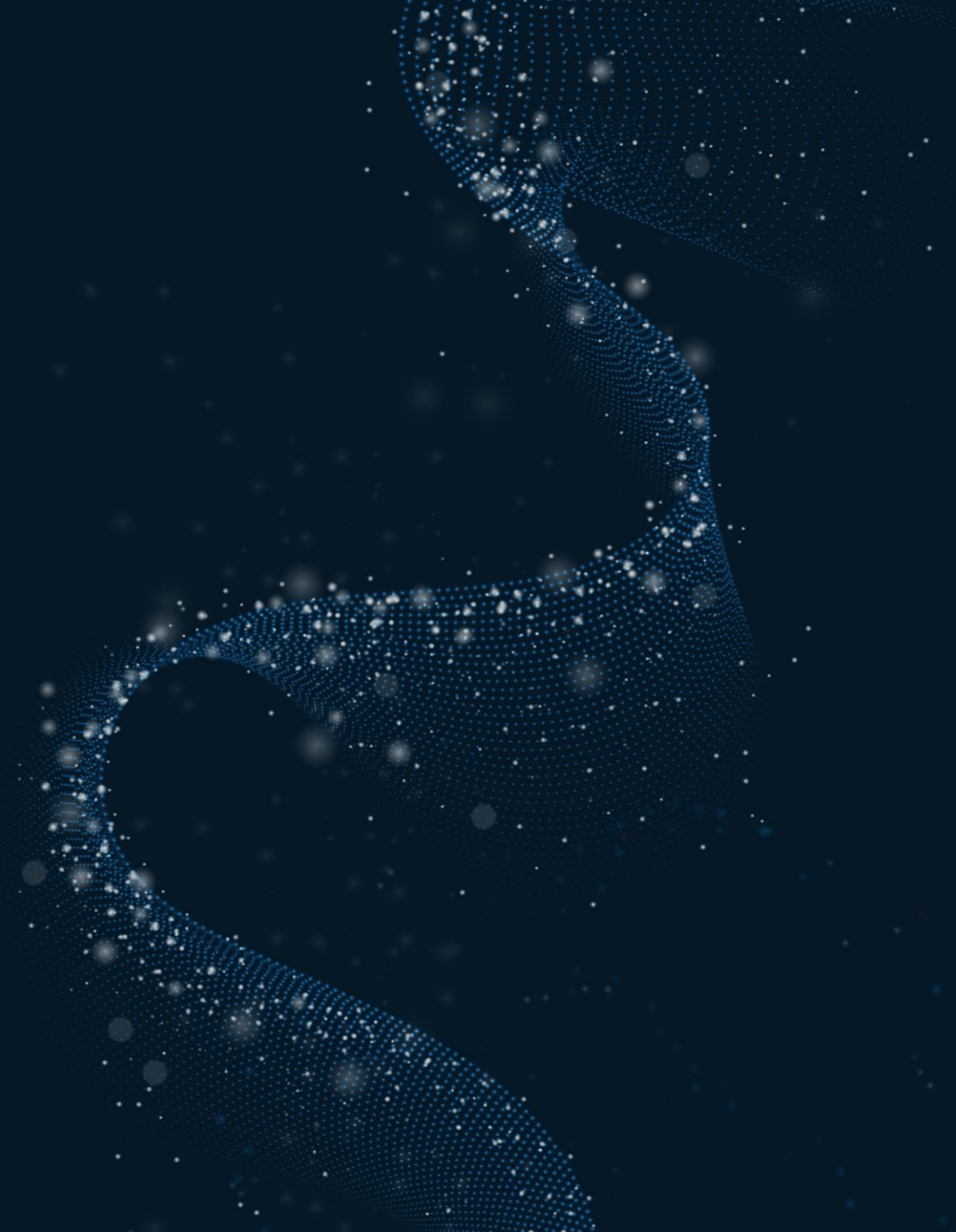
KROLL

CTI Spotlight Trends Report

May 2024



Methodology

- Kroll CTI monthly spotlights are based on intelligence from Kroll's cyber incident response engagements where we are engaged to respond, manage, or mitigate a cybersecurity incident. Kroll's incident response work is informed by intelligence gained from the 3,000+ engagements handled per year by the Kroll Cyber Risk team.
- Data is collected and processed by the Kroll Cyber Threat Intelligence team during the initial scoping intake as well as during the lifecycle of a Kroll engagement.
- Kroll currently reports on data on a monthly and quarterly basis through the monthly spotlights and Quarterly Threat Landscape reports.

Key Takeaways

Initial Access Methods

- **Phishing – Link** (27%)
- **Valid Accounts – Insider** (24%)
- **Social Engineering** (19%)

Most Impacted Sectors

- **Professional Services** (21%)
- **Healthcare** (14%)
- **Retail/Restaurant** (12%)
- **Manufacturing** (12%)

Top Ransomware Variants

- **FOG** (20%)
- **LOCKBIT** (10%)
- **AKIRA** (10%)

Top Threat Incident Types

- **Email Compromise** (47%)
- **Ransomware** (16%)
- **Insider Threat** (10%)

Sector Analysis

May 2024

PROFESSIONAL SERVICES IS THE MOST IMPACTED SECTOR THROUGHOUT MAY 2024

- **Email Compromise** was the top threat incident type impacting the professional services sector.
- In May, threats against the professional services sector most often involved **Phishing – Link** and **Social Engineering** as the initial access method.

HEALTHCARE AND RETAIL/RESTAURANT WERE THE 2nd and 3rd MOST IMPACTED SECTORS IN MAY 2024

- **Email Compromise** was the top reported threat incident type impacting both sectors.

Ransomware Analysis

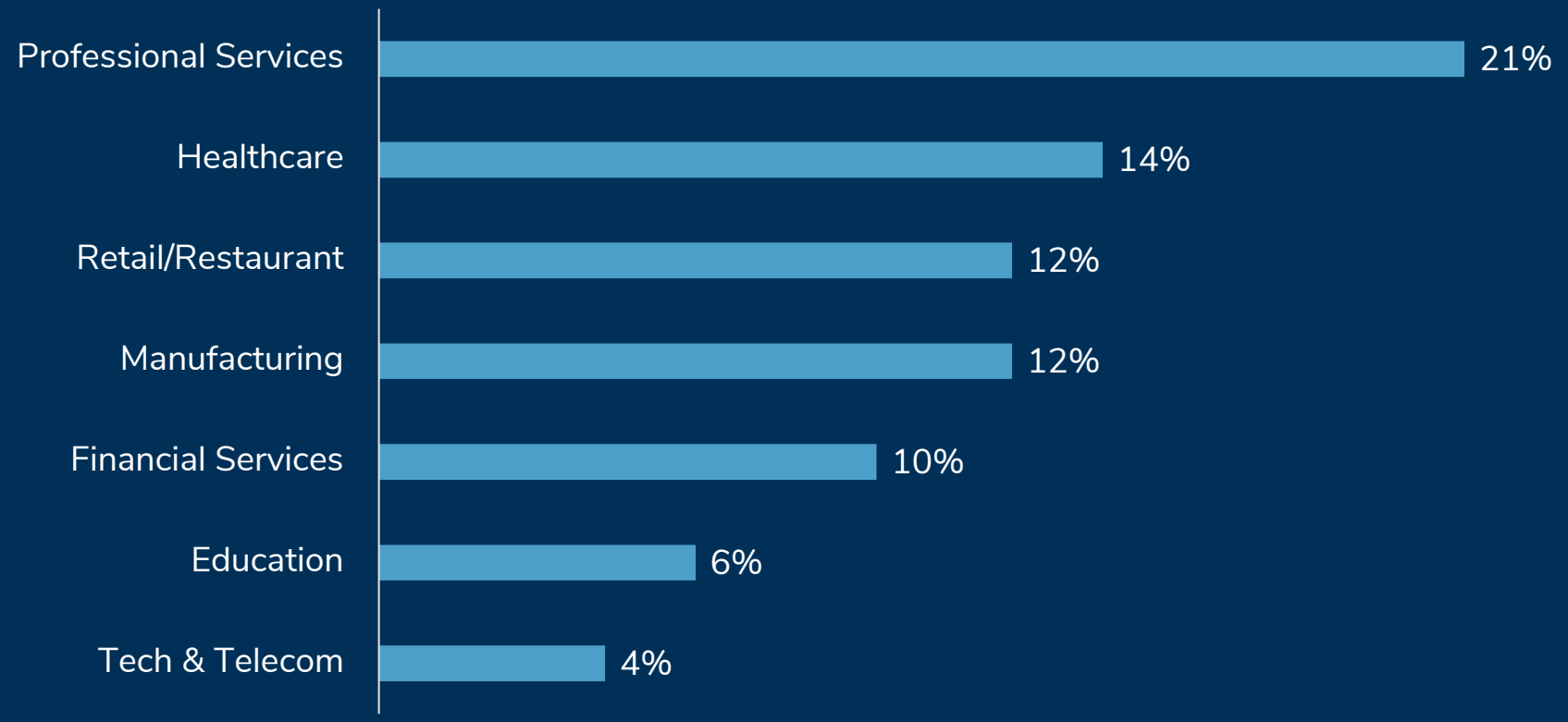
May 2024

CVE/ZERO-DAY EXPLOIT WAS THE MOST COMMON INITIAL ACCESS METHOD FOR RANSOMWARE OPERATORS IN MAY 2024

- **CVE-2024-3400** and **CVE-2024-24919** were the top vulnerabilities exploited.
  - **MEDUSA** was observed exploiting **CVE-2024-24919.**
  - **ROBINHOOD** was observed exploiting **CVE-2024-3400**.
- **FOG** was observed most frequently to target the healthcare and education sectors.
- **Drive-By Compromise, External Remote Services,** and **Social Engineering** were the second most observed initial access method in ransomware engagements.

Incidents by Sector

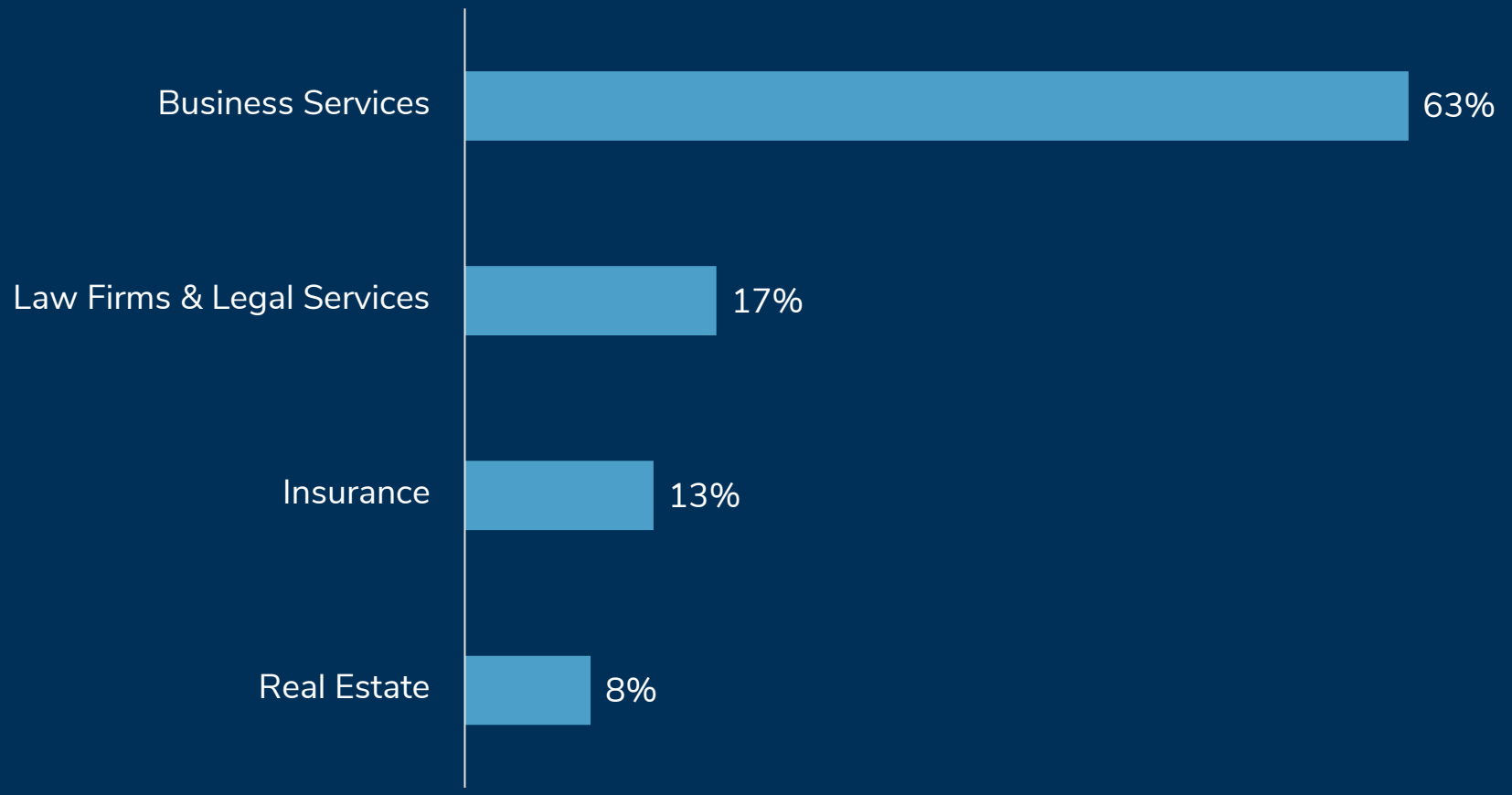
Top 7 impacted industries



TLP: AMBER

Professional Services Breakdown

May 2024

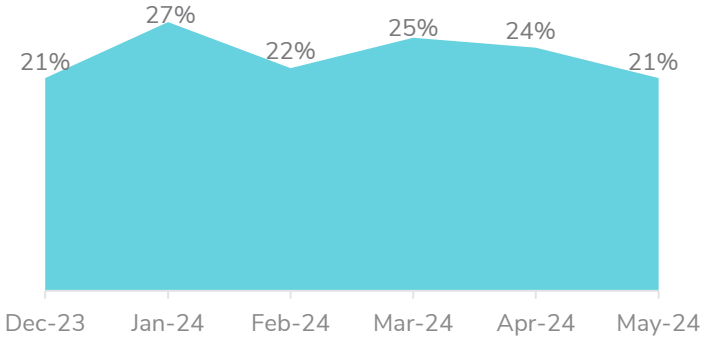


TLP: AMBER

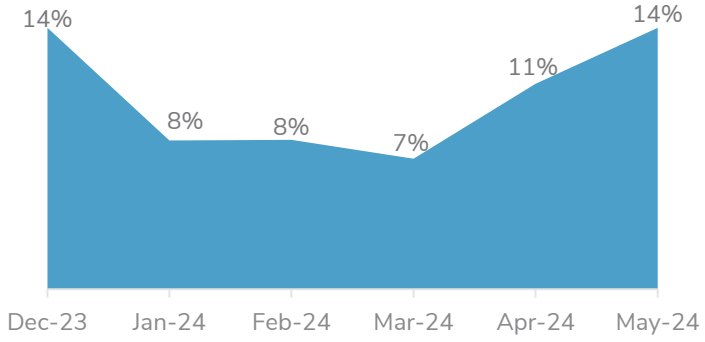
Most Impacted Sectors

Previous 6 Months

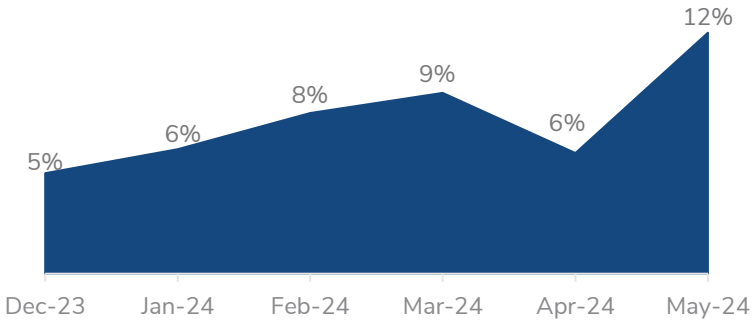
Professional Services



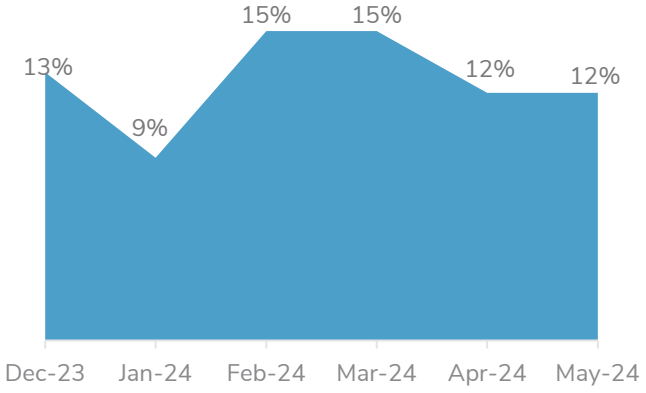
Healthcare



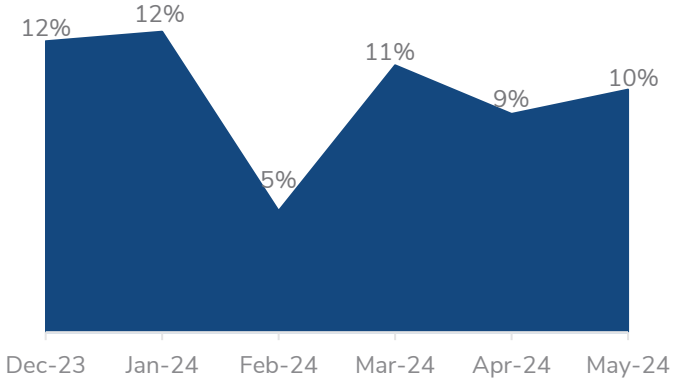
Retail/Restaurant



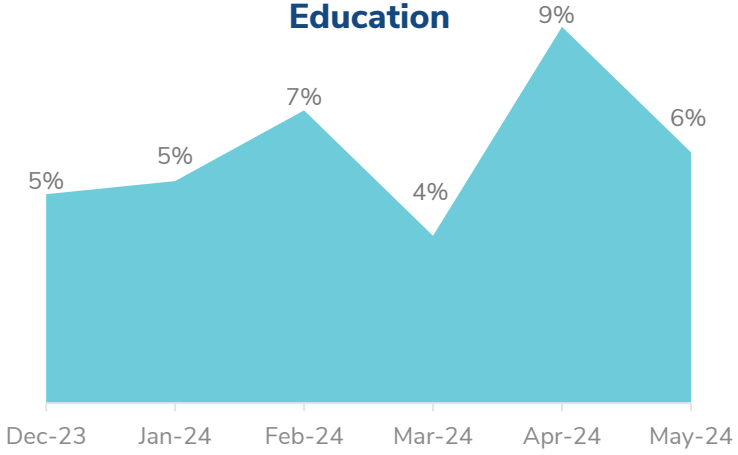
Manufacturing



Financial Services

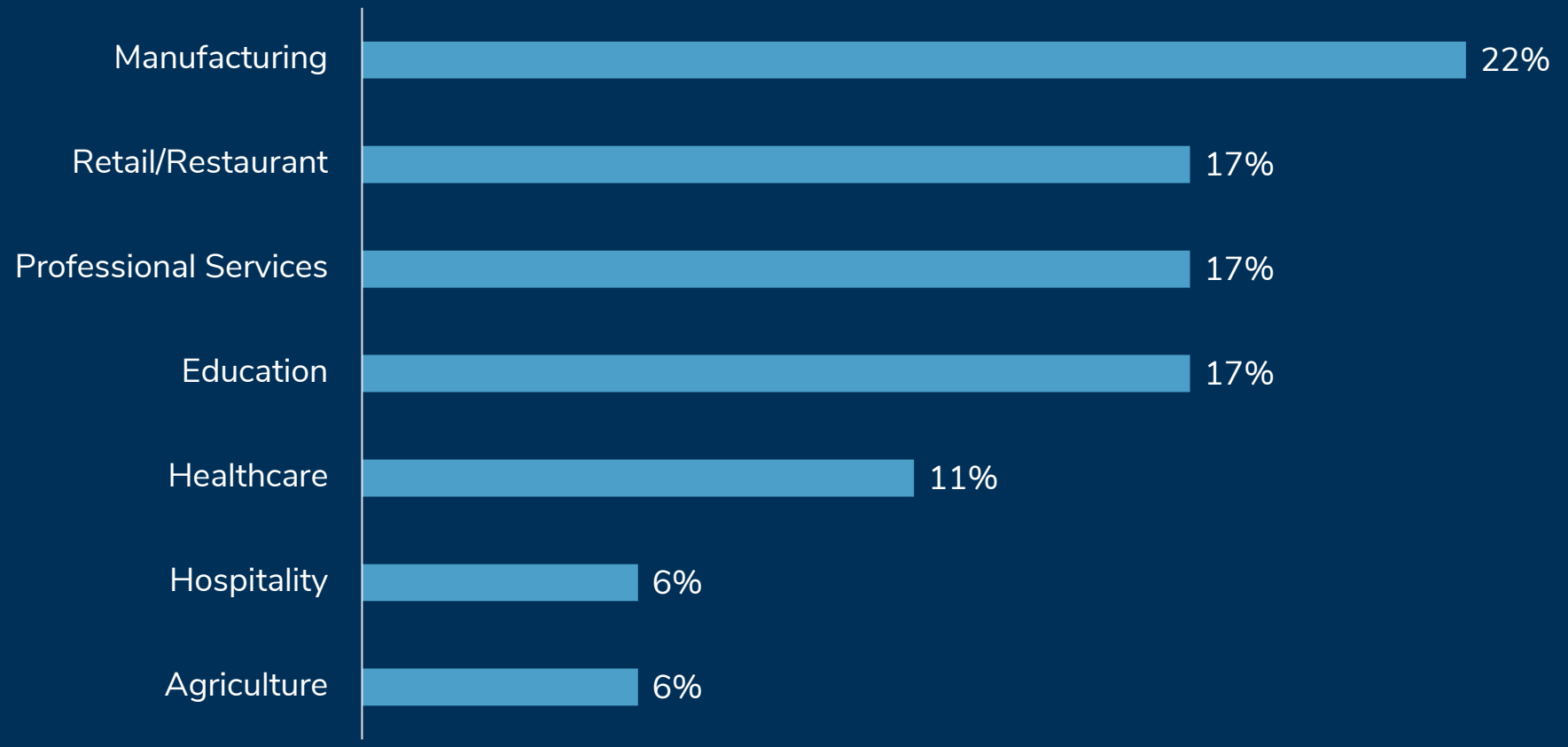


Education



Ransomware – Top Impacted Sectors

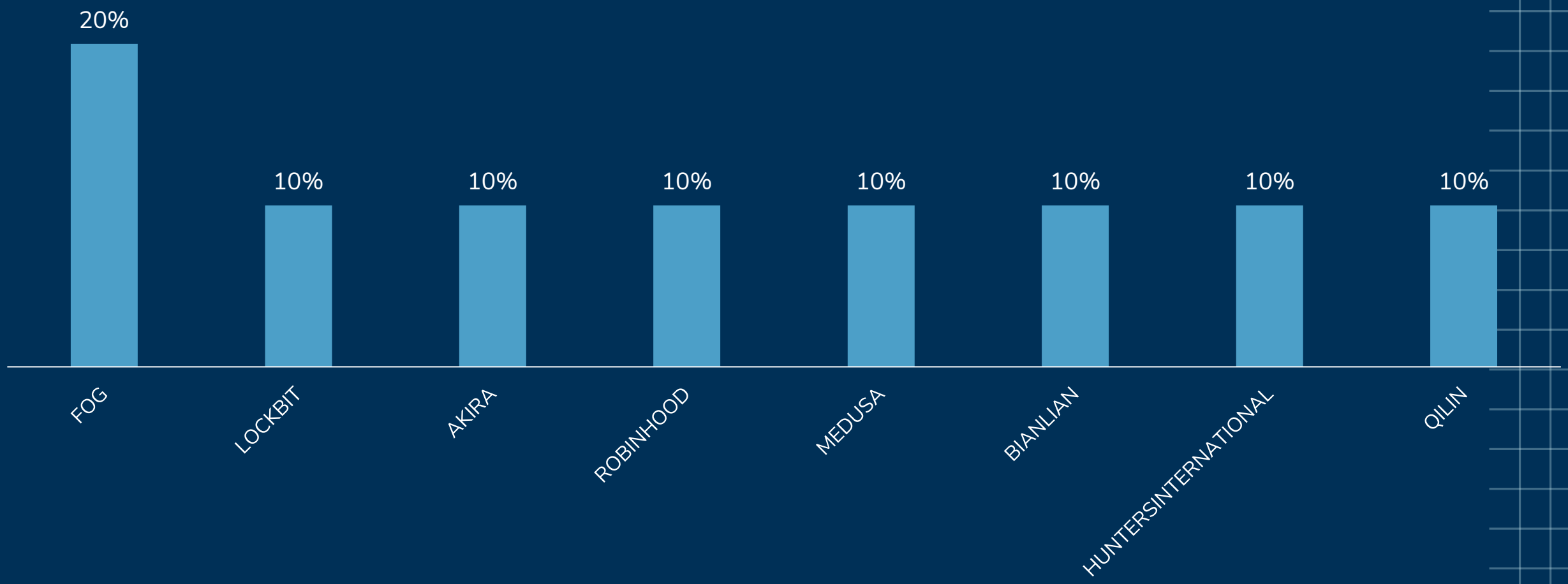
May 2024



TLP: AMBER

Top Ransomware Variants

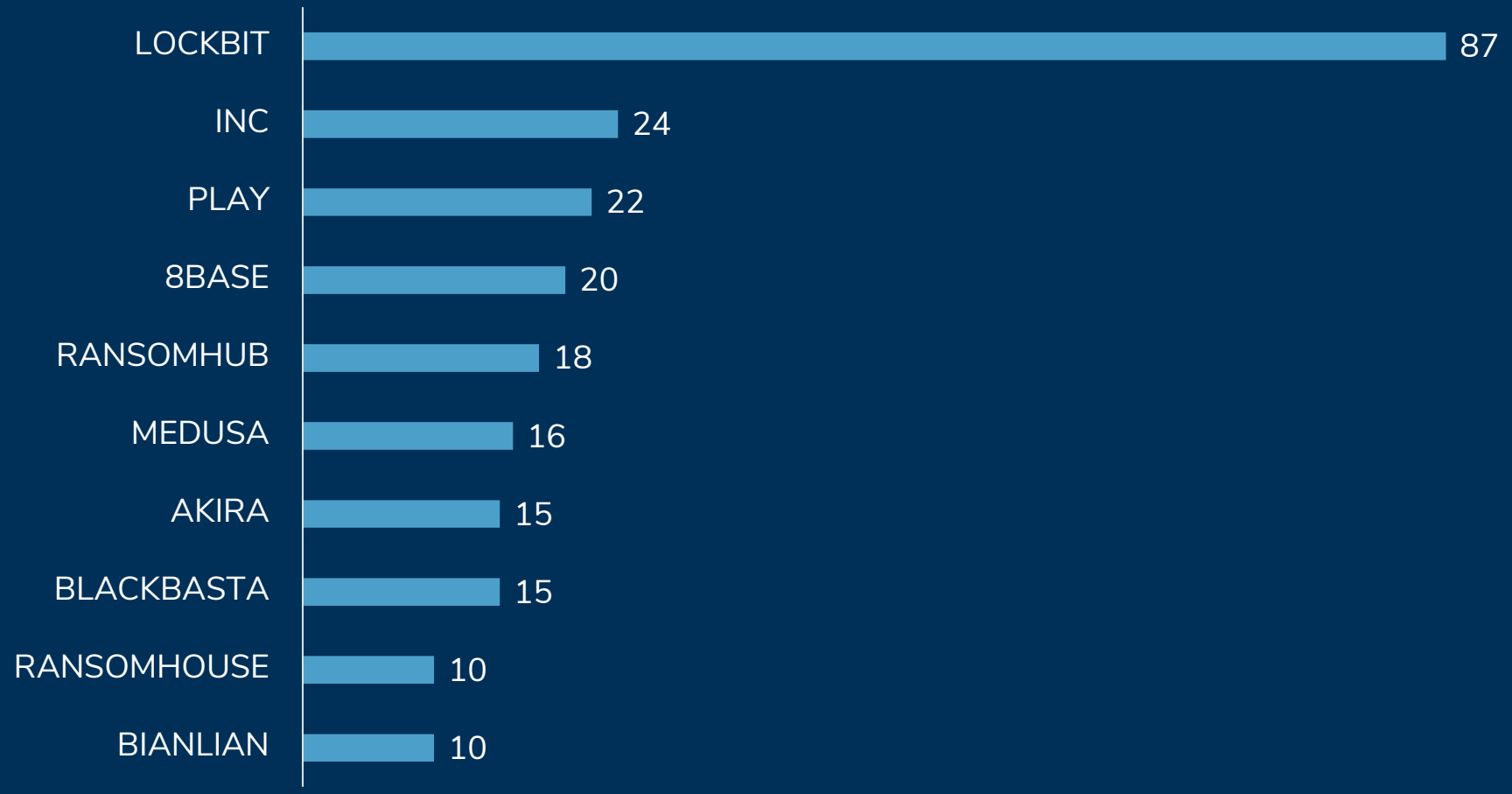
May 2024



TLP: AMBER

Ransomware – Actor-Controlled Site Listings

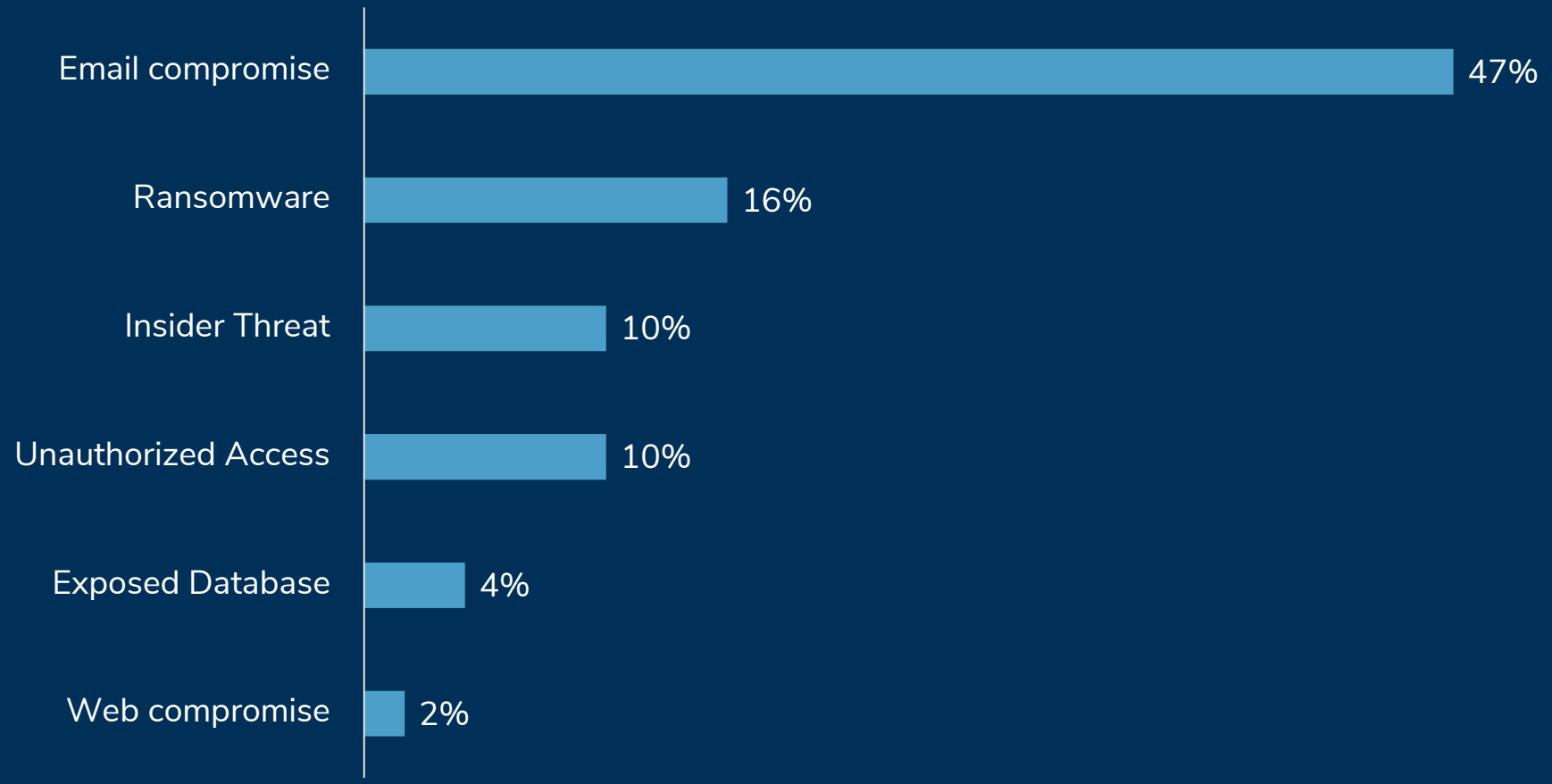
May 2024



TLP: AMBER

Incidents by Threat Type

May 2024



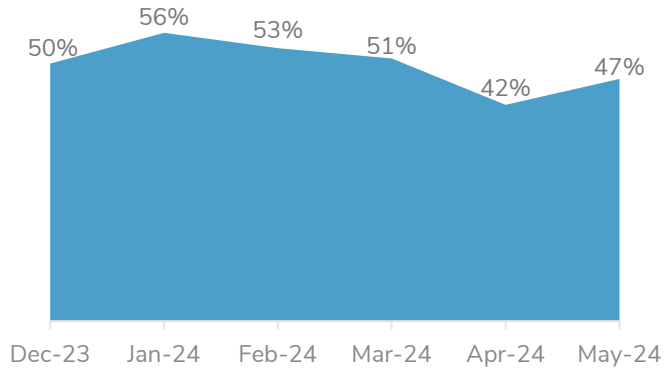
*Remaining 11% consists of Malware and Other Threat Incident Type

TLP: AMBER

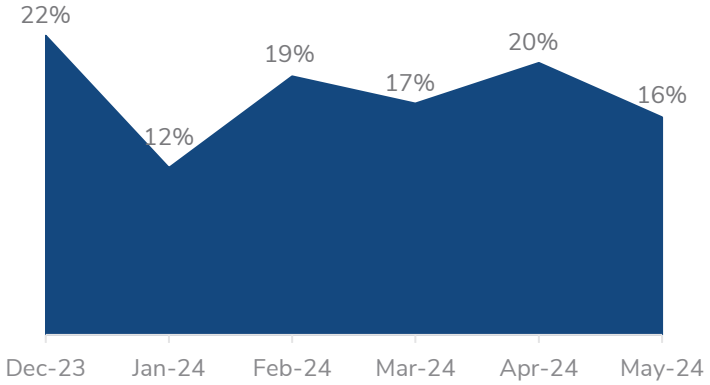
Threat Type Trends

Previous 6 Months

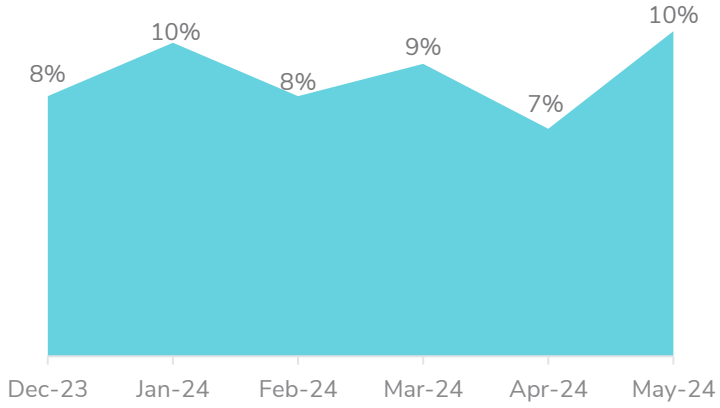
Email Compromise



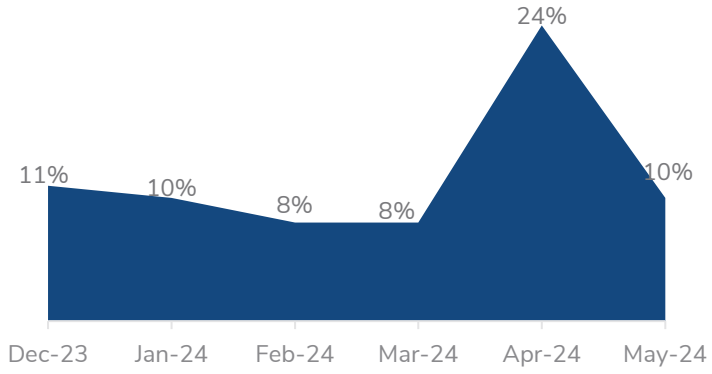
Ransomware



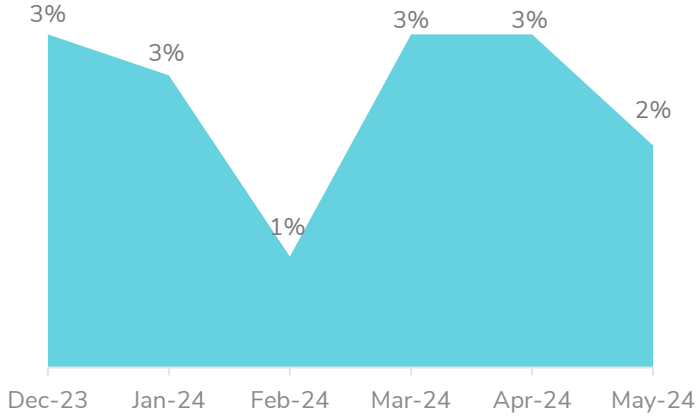
Insider Threat



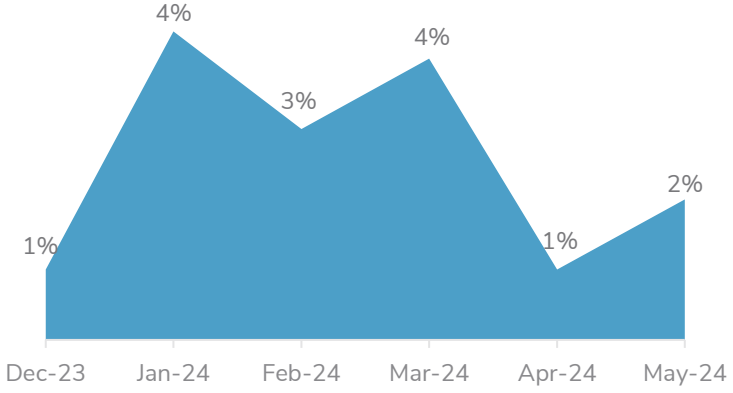
Unauthorized Access *



Malware - Other



Web Compromise

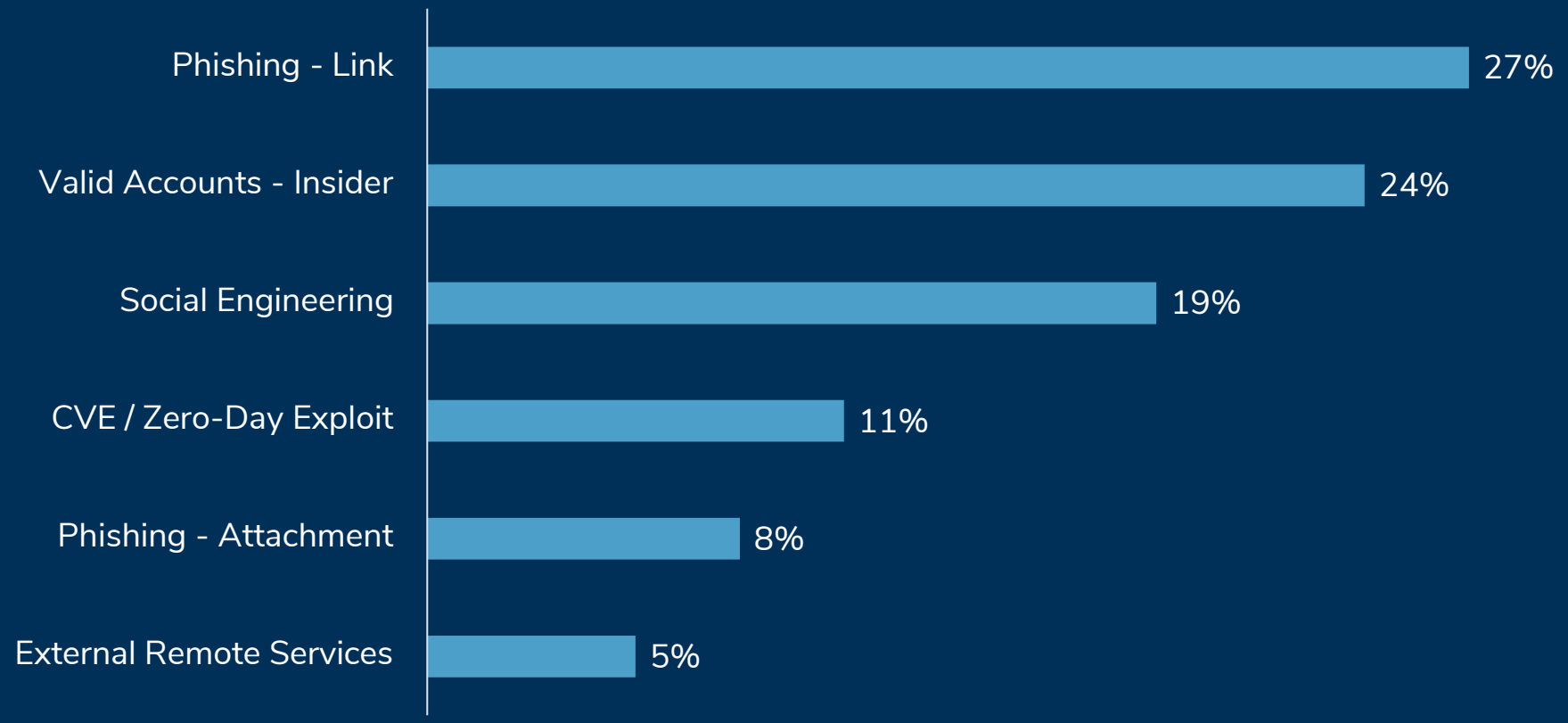


*Unauthorized Access represents a summation of Unauthorized Access - Network and Unauthorized Access - Cloud / Repository Access

TLP: AMBER

Initial Access Methods

Top 7 vectors



TLP: AMBER

Trending Vulnerabilities

May 2024

CVE	Vendor/Software	Advisory
CVE-2024-3400	Palo Alto Networks	https://nvd.nist.gov/vuln/detail/CVE-2024-3400
CVE 2024-24919	Check Point Software	https://nvd.nist.gov/vuln/detail/CVE-2024-24919
CVE 2024-27348	Apache HugeGraph-Server	https://nvd.nist.gov/vuln/detail/CVE-2024-27348
CVE 2024-4835	GitHub	https://nvd.nist.gov/vuln/detail/CVE-2024-4835
CVE 2024-27130	QNAP	https://nvd.nist.gov/vuln/detail/CVE-2024-27130

Threat Incident Types

Email Compromise: An event where email accounts are accessed maliciously by a third party (e.g., account takeover), a phishing email/campaign is identified, or an organization's email is used or compromised in a fraud scheme, such as a business email compromise.

Ransomware: An event where threat actors conduct malicious activity within a network followed by a demand for a financial ransom. Typically includes some combination of data exfiltration, data encryption, and extortion.

Malware – Other: An organization is impacted by a malware or virus where no financial demand is made. Examples include pre-ransomware activity (e.g., QakBot, Emotet) or information stealers (e.g., Vidar, Raccoon).

Unauthorized Access: An unauthorized actor has inadvertently or maliciously accessed a network.

Web Compromise: An actor has gained unauthorized access to web application or website code to conduct malicious activity. Examples include SQL injections to steal credit card data or website defacement.

Initial Access Methods

Drive-By Compromise: Compromise via a legitimate website.

External Remote Services: Compromise via remote access services such as VPNs.

Hardware Additions: Addition of computing device to gain access.

CVE / Zero-Day Exploit: Exploitation of a known or previously unknown vulnerability in an existing software.

Phishing – Attachment: Use of malware attached to an email.

Phishing – Link: Use of links in an email that lead to credential loss and/or downloading malware.

Supply Chain Compromise: Attack on weak links within an organization's supply chain (e.g., third-party vulnerability).

Social Engineering: Attempt to gain access to someone's personal or financial information via manipulation (e.g., Vishing, email impersonation).

Valid Accounts – Insider: The use of known credentials/legitimate or unrevoked access by an insider.

Valid Accounts – Externally Exposed: Account takeover via use of known credentials by external actor.

Additional Resources

See below for recent publications and upcoming events from Kroll's cyber threat intelligence team

Q1 2024 Cyber Threat Landscape Report: Insider Threat & Phishing Evolve Under AI Auspices - Kroll's Q1 2024 Threat Landscape Report looks into evolutions in techniques used in insider threat and phishing cases under the auspices of AI-driven tactics.

CVE-2024-24919: Zero-Day Vulnerability Detected in Check Point Products – A critical zero-day vulnerability, being tracked as CVE-2024-24919, has been discovered and patched in a number of Check Point products.

PLAY Ransomware Group Gains Access via Citrix Bleed Vulnerability – The PLAY Ransomware group continues to evolve its approach to include tactics such as gaining access via the Citrix Bleed vulnerability in order to encrypt systems after exfiltrating data.

Upcoming Webinar: Fighting Advanced Malware Threats: Kimsuky and the ScreenConnect Vulnerability

Wednesday, June 26; 11:00 AM – 11:45 AM EDT

Register here

On February 19, software firm ConnectWise notified clients of two vulnerabilities (CVE-2024-1708 and CVE-2024-1709) impacting on-premise versions of their remote management tool, ScreenConnect. Within days, the vulnerability was under heavy exploitation from several groups, including the Advanced Persistent Threat (APT) group known as Kimsuky.

In this exclusive briefing Kroll's Head of Threat Intelligence in EMEA, George Glass, will address how Kimusky weaponized the ScreenConnect vulnerability using new malware strain TODDLERSHARK.

Definitions

Traffic Light Protocol (TLP)

Color	When should it be used?	How may it be shared?
TLP:RED **Not for disclosure, restricted to participants only.**	Sources may use **TLP:RED** when information cannot be effectively acted upon by additional parties, and could lead to impacts on a party's privacy, reputation, or operations if misused.	Recipients may not share **TLP:RED** information with any parties outside of the specific exchange, meeting, or conversation in which it was originally disclosed. In the context of a meeting, for example, **TLP:RED** information is limited to those present at the meeting. In most circumstances, **TLP:RED** should be exchanged verbally or in person.
TLP:AMBER+STRICT **Limited disclosure, restricted to participants' organization only.**	Sources may use **TLP:AMBER+STRICT** when information requires support to be effectively acted upon, yet carries risks to privacy, reputation, or operations if shared outside of the organizations involved.	Recipients may only share **TLP:AMBER+STRICT** information with members of their own ***organization*** who need to know the information to protect themselves or prevent further harm. **Sources are at liberty to specify additional intended limits of the sharing: these must be adhered to.**
TLP:AMBER **Limited disclosure, restricted to participants' organizations and clients.**	Sources may use **TLP:AMBER** when information requires support to be effectively acted upon, yet carries risks to privacy, reputation, or operations if shared outside of the organizations involved.	Recipients may only share **TLP:AMBER** information with members of their own ***organization and with clients or customers*** who need to know the information to protect themselves or prevent further harm. **Sources are at liberty to specify additional intended limits of the sharing: these must be adhered to.**
TLP:GREEN **Limited disclosure, restricted to the community.**	Sources may use **TLP:GREEN** when information is useful for the awareness of all participating organizations as well as with peers within the broader community or sector.	Recipients may share **TLP:GREEN** information with peers and partner organizations within their sector or community, but not via publicly accessible channels. Information in this category can be circulated widely within a particular community. **TLP:GREEN** information may not be released outside of the community.
TLP:CLEAR **Disclosure is not limited.**	Sources may use **TLP:CLEAR** when information carries minimal or no foreseeable risk of misuse, in accordance with applicable rules and procedures for public release.	Subject to standard copyright rules, **TLP:CLEAR** information may be distributed without restriction.

KROLL

For more information, please contact:

Keith Wojcieszek
Managing Director, Cyber Risk
1 443 295 5082
keith.wojcieszek@kroll.com

Laurie Iacono
Associate Managing Director, Cyber Risk
1 412 588 4337
laurie.iacono@kroll.com

About Kroll

As the leading independent provider of risk and financial advisory solutions, Kroll leverages our unique insights, data and technology to help clients stay ahead of complex demands. Kroll's global team continues the firm's nearly 100-year history of trusted expertise spanning risk, governance, transactions and valuation. Our advanced solutions and intelligence provide clients the foresight they need to create an enduring competitive advantage. At Kroll, our values define who we are and how we partner with clients and communities. Learn more at www.kroll.com.

M&A advisory, capital raising and secondary market advisory services in the United States are provided by Kroll Securities, LLC (member FINRA/SIPC). M&A advisory, capital raising and secondary market advisory services in the United Kingdom are provided by Kroll Securities Ltd., which is authorized and regulated by the Financial Conduct Authority (FCA). Valuation Advisory Services in India are provided by Kroll Advisory Private Limited (formerly, Duff & Phelps India Private Limited), under a category 1 merchant banker license issued by the Securities and Exchange Board of India.

© 2023 Kroll, LLC. All rights reserved.